SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

COMPUTER SCIENCE AND ENGINEERING

Nov – 2026

ASSIGNMENT – 3

Name : **T.Raju**

Reg_No : **192465038**

Course Code : **CSA63**

Course Name : **THREAT INTELLIGENCE AND NETWORK SECURITY**

Max Marks**: 50**

Answer all the Questions

1	A small software company has an office network of about fifty users, a web server and a mail server that must be reachable from the Internet, an internal file server, and an administrator who manages the servers over SSH. The company has one Internet connection and wants to place a firewall at the edge. Apply the concepts of firewalls to this network. Explain the types of firewalls (stateless packet filtering, stateful inspection, application-level gateway or proxy, next-generation firewall and web application firewall) with their strengths and limits, and the role of a DMZ and of network address translation. Prepare an ordered firewall rule table of at least eight rules (action, source, destination, protocol and port, direction and reason) that allows only the required traffic, applies ingress and egress filtering and ends with a default-deny rule. Explain why the order of rules matters, and describe how the rules are tested, logged and reviewed.	(10)	(CO4)	(BL3)
2	The SOC of a university receives about two thousand alerts a day from its intrusion detection system, and analysts estimate that more than ninety per cent are false positives, so a real intrusion in the student hostel network has gone unnoticed for two weeks. Analyse the situation using the concepts of IDS and IPS. Compare network-based and host-based systems, signature-based, anomaly-based and hybrid detection, and passive IDS (SPAN port or network tap) with inline IPS, and explain where sensors should be placed. Explain false positives and false negatives with examples and the cost of each. Interpret this Snort-style rule and say what it detects and how it could be tuned: alert tcp any any -> $HOME_NET 22 (msg:"SSH brute force"; flags:S; threshold:type both, track by_src, count 5, seconds 60; sid:1000001; rev:1;). Recommend a tuning and response process, and discuss how attackers try to evade detection (for example, fragmentation, encryption and slow scans).	(10)	(CO4)	(BL4)

3	A retail company has a head office, ten branch stores and about two hundred staff who sometimes work from home. Branch stores send sales data to the head office, and remote staff need access to the internal inventory system. Apply VPN and secure communication techniques to this requirement. Explain site-to-site and remote-access VPNs, the working of IPsec (AH and ESP, transport and tunnel mode, security associations and IKE) and of SSL/TLS VPNs, and the difference	(10)	(CO4)	(BL3)
	between split tunnelling and full tunnelling. Draw a labelled diagram showing which VPN type is used for the branch stores and which for the remote staff, and justify the choice. Explain the role of TLS and SSH for secure communication of applications and administration, and discuss the security and operational issues of the design, such as multi-factor authentication, key and certificate management, logging, performance and the risk of a compromised home device.			
4	A manufacturing company runs its office computers, ERP servers, guest Wi-Fi, IP cameras and the production-line control systems on one flat network. Last month a ransomware infection on an office laptop spread to the ERP servers and stopped the production line for two days. Analyse how network segmentation and secure architecture design could have limited the damage. Explain VLANs, subnets, internal firewalls and access control lists, a DMZ and micro-segmentation, and design a zone-based architecture with at least five zones (for example, office, servers, DMZ, guest, camera and production) with a table of the traffic that is allowed between zones and the reason for each. Explain how administrators should reach the production zone (for example, through a jump host with multi-factor authentication). Discuss the principles of secure architecture design (least privilege, simplicity, fail-safe defaults, redundancy and separation of duties) and the costs and limits of segmentation.	(10)	(CO4)	(BL4)
5	A financial services firm has moved most of its applications to the cloud and about half of its staff work remotely. A recent breach began with stolen VPN credentials, after which the attacker moved freely across the internal network because the firm trusted everything inside its perimeter. Evaluate the use of the Zero Trust model and the defense-in-depth strategy for this firm. Explain the principles of Zero Trust (never trust and always verify, least privilege, assume breach) and its components (identity provider, multi-factor authentication, device posture checks, policy decision and enforcement points, micro-segmentation and continuous monitoring). Explain the layers of defense in depth (physical, perimeter, network, host, application, data, people and policy) and map one control to each layer for this firm. Evaluate Zero Trust against the traditional perimeter model, explain how the two approaches complement each other, and recommend a phased roadmap with the difficulties the firm is likely to meet, such as legacy systems, user resistance and cost.	(10)	(CO4)	(BL5)

QUESTION 1

Firewall Design for a Small Software Company

A firewall is a security device or software that monitors and controls incoming and outgoing network traffic according to a set of rules. For the company with approximately fifty users, a web server, a mail server, an internal file server and SSH-based administration, the firewall should separate the trusted internal network from the Internet and expose only the services that must be public.

1.1 Types of Firewalls: Strengths and Limitations

Firewall type	How it works	Strengths	Limitations
Stateless packet filtering	Checks each packet independently using source/destination IP address, protocol and port.	Fast, simple and uses few resources; suitable for basic filtering.	Does not remember connections; limited application awareness; complex rule sets can be difficult to manage.
Stateful inspection	Tracks connection state and allows packets that belong to valid established sessions.	More secure than stateless filtering; handles return traffic conveniently; reduces spoofed or unsolicited traffic.	Consumes more resources; may not understand application content; statetable exhaustion is possible.
Application-level gateway / proxy	Terminates a client connection and creates a separate connection to the destination while inspecting application requests.	Can inspect application commands and content; hides internal addresses; supports detailed logging and authentication.	Can introduce latency; requires application-specific configuration; may not support every protocol.
Next-generation firewall (NGFW)	Combines stateful filtering with application identification, intrusion prevention, user awareness and threat intelligence.	Provides deeper inspection, application control and integrated threat blocking.	More expensive and complex; encrypted traffic inspection needs careful certificate and privacy management.
Web application firewall (WAF)	Inspects HTTP/HTTPS requests to web applications and blocks attacks such as SQL injection and cross-site scripting.	Protects web applications at Layer 7; can use managed rules and virtual patching.	Protects web traffic only; cannot replace a network firewall or secure vulnerable application code completely.

1.2 DMZ and Network Address Translation

A demilitarized zone (DMZ) is a separate network placed between the Internet and the trusted office LAN. The public web and mail servers should be placed in the DMZ. If one of these servers is compromised, the attacker should not automatically gain access to the internal file server or user computers. The firewall controls traffic between the Internet, DMZ and internal LAN.

Network Address Translation (NAT) translates private internal IP addresses into a public address for Internet communication. Source NAT/PAT allows many office users to share one public IP address. Destination NAT or port forwarding maps selected public ports to the web and mail servers in the DMZ. NAT hides internal addressing but is not a substitute for firewall filtering.

1.3 Proposed Network Layout

Internet → Edge firewall → DMZ (public web server and mail server). A separate firewall interface connects to the internal LAN (fifty user computers and file server). The administrator connects through an approved management VPN or a restricted trusted management address, then uses SSH to administer servers. The file server is never directly reachable from the Internet.

1.4 Ordered Firewall Rule Table

The following is an example policy. Replace the example network ranges and server addresses with the company's actual assigned addresses. Rules are evaluated from top to bottom; the first matching rule is applied.

No.	Action	Source	Destination	Protocol / port	Direction	Reason
1	Allow	Internet	DMZ web server	TCP 443 (and TCP 80 only for HTTPS redirect)	Inbound	Publish the company website; avoid exposing other ports.
2	Allow	Internet mail servers	DMZ mail gateway	TCP 25; TCP 587/465 only if required	Inbound	Receive mail and authenticated mail submission.
3	Allow	DMZ mail gateway	Approved Internet mail hosts	TCP 25	Outbound	Permit the mail gateway to deliver outgoing email.
4	Allow	Internal users	Internet	TCP 80/443; DNS to approved resolver	Outbound	Allow normal web access and name resolution.
5	Allow	Internal users	DMZ mail server	TCP 587/465 and approved mail access ports	Internal → DMZ	Allow staff to send and retrieve company email.

6	Allow	Internal users	Internal file server	Required file-sharing ports only (e.g. TCP 445 where SMB is used)	Internal	Permit business file access; restrict to approved user subnet.
7	Allow	Admin VPN / management subnet	DMZ and internal servers	TCP 22 (SSH)	Inbound to servers	Allow SSH only from the administrator's authenticated management path.
8	Allow	DMZ web server	Approved application/database service in server subnet	Specific application port only	DMZ → Internal server zone	Permit only the backend connection required by the website; do not allow general DMZ access.
9	Deny and log	DMZ	Internal user LAN and file server	Any	DMZ → Internal	Prevent public-facing systems from initiating unnecessary connections into the office network.
10	Deny and log	Internet	Internal LAN and file server	Any	Inbound	Block direct Internet access to private systems.
11	Deny and log	Internal network	Internet	Unapproved ports/protocols	Outbound	Apply egress filtering and reduce malware command-and-control or dataexfiltration paths.
12	Deny and log	Any	Any	Any	Both directions	Default deny: block all traffic not explicitly permitted.

1.5 Why Rule Order Matters

Firewall rules are generally processed sequentially. A broad allow rule placed above a specific deny rule may unintentionally permit dangerous traffic. Specific rules should therefore appear before general rules, and the defaultdeny rule must be last. Related return traffic should be allowed through stateful inspection rather than by opening broad inbound port ranges.

1.6 Testing, Logging and Review

- Test permitted services from the correct network locations, for example HTTPS to the public website and SSH from the management VPN.
- Test prohibited paths, such as direct Internet access to the file server, SSH from an ordinary user device and DMZto-LAN access.
- Use port-scanning and connection tests only on systems owned by the company or for which written authorization has been obtained.
- Enable logs for denied traffic, administrative changes, VPN access and important allowed connections. Send logs to a central, time-synchronized logging server.
- Review rule hits and unused rules regularly, remove temporary rules after their expiry, verify backups and test firewall changes in a controlled change process.

Thus, a DMZ, restrictive ingress and egress rules, NAT and a final default-deny policy provide layered protection while keeping the required public services available.

QUESTION 2

IDS and IPS Analysis for a University SOC

An Intrusion Detection System (IDS) monitors activity and raises alerts when it identifies suspicious behaviour. An Intrusion Prevention System (IPS) can also take action, such as dropping packets or blocking a source. The university's two thousand daily alerts and very high false-positive rate indicate poor detection tuning, weak prioritisation or insufficient context. Because a real intrusion remained unnoticed for two weeks, the SOC should improve visibility, detection quality and incident investigation rather than simply reducing the number of alerts. **2.1 Network-Based and Host-Based Systems**

System	Monitoring location and data	Advantages	Limitations
Network-based IDS/IPS (NIDS/NIPS)	Monitors network traffic at strategic links, such as the Internet gateway, data-centre boundary and hostel VLAN uplink.	Can detect scans, suspicious connections and attacks across many devices; provides network-wide visibility.	Encrypted payloads may be hidden; high-speed links can overwhelm sensors; traffic outside the sensor path may be missed.
Host-based IDS/IPS (HIDS/HIPS)	Runs on endpoints and servers; monitors system logs, processes, files, registry/configuration changes and local connections.	Can see activity after decryption and detect local changes or malware behaviour.	Requires deployment and maintenance on every host; consumes endpoint resources; may be disabled by an attacker with administrator privileges.

2.2 Detection Methods

- Signature-based detection compares activity with known attack patterns. It is accurate for known threats but may miss new or modified attacks.
- Anomaly-based detection learns or defines normal behaviour and flags deviations, such as a student account suddenly transferring unusually large amounts of data. It can detect unknown attacks but may generate false positives when legitimate behaviour changes.
- Hybrid detection combines signatures, behavioural baselines and contextual information. It offers broader coverage, but needs careful tuning and skilled analysts.

2.3 Passive IDS and Inline IPS; Sensor Placement

A passive IDS receives a copy of network traffic through a SPAN/mirror port on a switch or a network tap. It observes and alerts without directly interrupting traffic. An inline IPS sits directly in the traffic path and can block malicious packets, but an incorrect rule or device failure can interrupt legitimate services.

For the university, place network sensors at the Internet edge, the data-centre/server network boundary, the hostel network uplink and important inter-VLAN links. Deploy host agents on critical servers, identity systems and selected student-lab systems. A sensor should see the traffic relevant to its purpose; SPAN configurations must be checked for packet loss.

2.4 False Positives and False Negatives

Type	Meaning	Example	Likely cost
False positive	Benign activity is incorrectly reported as malicious.	A legitimate student downloads a large course file and triggers an exfiltration alert.	Alert fatigue, wasted analyst time, unnecessary account blocks and important alerts being ignored.
False negative	A real attack is not detected.	An attacker slowly guesses SSH passwords from the hostel network without crossing a detection threshold.	Account compromise, data theft, service disruption, financial loss and reputational damage.

False negatives are particularly dangerous because the attack may continue without the SOC knowing. False positives are also harmful because excessive noise reduces the chance that analysts notice genuine incidents.

2.5 Interpretation of the Snort-Style Rule

```
alert tcp any any -> $HOME_NET 22 (msg:"SSH brute force"; flags:S; threshold:type both, track by_src, count 5, seconds 60; sid:1000001; rev:1;)
```

This rule generates an alert for TCP packets from any source IP and source port to any destination in $HOME_NET on destination port 22. The flags:S condition matches TCP SYN packets, which commonly begin connection attempts. The threshold tracks each source IP and uses a count of five within sixty seconds. With type both, the rule is intended to alert at the configured threshold while limiting repeated alerts for the same source. It is an indicator of repeated SSH connection attempts, not proof that passwords were successfully guessed.

Tuning recommendations:

- Apply the rule to the actual SSH server addresses and authorised management paths rather than every host in the home network variable.
- Exclude approved vulnerability scanners and management systems only after verifying their identity and documenting the exception.
- Correlate connection attempts with SSH authentication logs, failed-login events and successful logins. A network SYN count alone cannot confirm password failures.
- Use a time window and threshold suited to the environment; consider distributed attempts from many source addresses and slow attempts below the threshold.
- Create separate severity levels for repeated failures followed by a successful login, attempts against privileged accounts and activity from unusual locations.

2.6 Recommended Tuning and Response Process

1. Establish asset and user context: identify critical systems, normal traffic patterns, approved scanners and expected maintenance windows.
2. Classify alerts by severity, confidence, asset importance and threat intelligence. Deduplicate repeated alerts and group related events.
3. Tune rules using verified false-positive cases. Keep a record of each change, its owner, reason and review date.
4. Correlate network alerts with endpoint, authentication, DNS, DHCP, VPN and firewall logs in a SIEM.
5. For a credible incident, preserve evidence, validate the alert, isolate affected hosts when necessary, disable compromised accounts, block malicious indicators and follow the incident-response plan.
6. After recovery, identify the detection gap, update rules and baselines, and conduct a lessons-learned review.

2.7 Common IDS/IPS Evasion Techniques

- Fragmentation: attackers split packets into fragments to confuse sensors or exploit differences in packet reassembly. Sensors should perform consistent reassembly and reject malformed traffic.
- Encryption: TLS or SSH encryption can hide payload content. Use metadata, endpoint telemetry, approved TLS inspection where lawful, and server-side logs.
- Slow scans: attackers spread probes over long periods to remain below simple thresholds. Use longer behavioural windows and correlate events across time.
- Other evasions include spoofed addresses, protocol tunnelling and changing payload patterns. Normalisation, secure network design and multiple telemetry sources reduce these blind spots.

The university should combine NIDS/NIPS and host monitoring, tune alerts using real operational data and establish a clear response process. This reduces alert fatigue while improving the chance of detecting genuine intrusions.

QUESTION 3

VPN and Secure Communication Design for a Retail Company

The retail company needs secure communication between its head office and ten branches, and secure access for approximately two hundred remote employees. A suitable design uses site-to-site VPN tunnels for branch connectivity and remote-access VPN for individual staff.

3.1 Site-to-Site and Remote-Access VPNs

- A site-to-site VPN connects entire networks, usually through VPN gateways at each branch and the head office. It is suitable for continuous transfer of sales data between stores and the head office.
- A remote-access VPN connects an individual user device to the company network through a VPN client or browserbased portal. It is suitable for staff working from home.

3.2 IPsec Operation

IPsec is a suite of protocols that protects IP communication. Authentication Header (AH) provides integrity, data-origin authentication and anti-replay protection, but does not encrypt the payload and is generally less practical where NAT is used. Encapsulating Security Payload (ESP) can provide confidentiality through encryption as well as integrity, authentication and anti-replay protection.

- Transport mode protects the IP payload while retaining the original IP header. It is commonly used for host-to-host communication.
- Tunnel mode encapsulates the complete original IP packet inside a new IP packet. It is commonly used for gatewayto-gateway site-to-site VPNs.
- A Security Association (SA) defines the security parameters for a one-way IPsec connection, including algorithms, keys, lifetime and security identifiers. Two directions normally require separate SAs.
- Internet Key Exchange (IKE/IKEv2) authenticates VPN peers, negotiates algorithms and creates/manages the keys and SAs. Certificates or strong pre-shared keys can be used for peer authentication; certificates are preferable for larger deployments.

3.3 SSL/TLS VPNs

A TLS VPN uses TLS to protect a connection between a remote user and a VPN gateway. It commonly uses TCP port 443, which is widely permitted through firewalls. Depending on the product, it can provide browser-based access to selected applications or a client-based tunnel for broader network access. It should use modern TLS versions, valid certificates and strong authentication.

3.4 Split Tunnelling and Full Tunnelling

Mode	Traffic path	Benefits	Risks / considerations
Split tunnelling	Only company-destined traffic uses the VPN; ordinary Internet traffic goes directly through the user's local connection.	Reduces VPN bandwidth use and can improve performance.	A device has simultaneous access to the public Internet and company network, increasing exposure if it is compromised.
Full tunnelling	All user traffic, including Internet traffic, passes through the company VPN gateway.	Centralised security inspection, filtering and logging.	Requires more VPN bandwidth and gateway capacity; can increase latency.

3.5 Labelled VPN Architecture

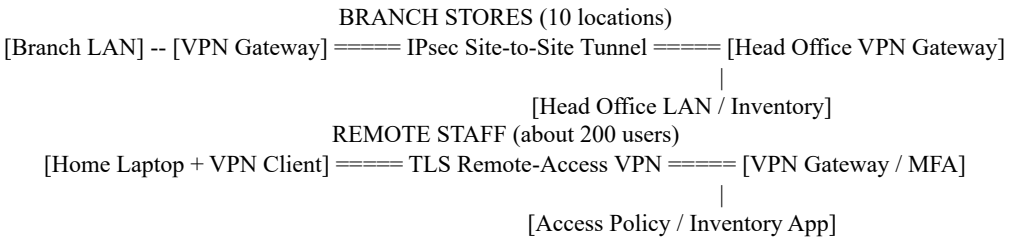


Figure 1: Proposed VPN architecture. The double lines represent encrypted VPN tunnels.

IPsec site-to-site VPN is appropriate for the ten branches because it securely connects each store network to the head office with little user involvement. Remote-access TLS VPN is appropriate for individual employees because it supports user authentication, MFA and controlled access to the inventory application. Access should be limited to the systems and services each user needs.

3.6 TLS and SSH for Applications and Administration

TLS protects application communication, such as HTTPS access to the inventory system and secure APIs. It provides encryption, integrity and server authentication; mutual TLS can also authenticate client systems. SSH provides encrypted remote command-line administration, file transfer and secure tunnelling. SSH access should use keys rather than passwords where practical, disable direct root login, restrict source networks and log administrative activity.

3.7 Security and Operational Considerations

- Require MFA for all remote access and privileged accounts. Prefer phishing-resistant methods where supported.
- Manage certificates centrally: issue them from a trusted certificate authority, monitor expiry, protect private keys and revoke compromised certificates.
- Use unique, strong VPN credentials and rotate or revoke credentials promptly when staff leave or devices are lost.
- Log VPN authentication, connection duration, assigned addresses, device identity and access to sensitive applications; forward logs to a SIEM.
- Size VPN gateways for peak branch and remote-user traffic. Monitor latency, throughput and availability, and maintain redundant gateways and Internet links where justified.
- Check device posture before access: supported operating system, endpoint protection, disk encryption, patch level and screen lock.
- A compromised home device can provide an attacker with a trusted VPN session. Use endpoint detection, leastprivilege application access, segmentation and rapid isolation procedures.

This design provides encrypted branch connectivity and identity-based remote access while controlling the systems that each connection can reach.

QUESTION 4

Network Segmentation and Secure Architecture for a Manufacturing Company

The company's flat network allows office computers, ERP servers, guest Wi-Fi, cameras and production controllers to communicate too freely. Therefore, ransomware on one office laptop was able to spread to ERP systems and disrupt production. Network segmentation divides the environment into separate security zones and permits only necessary communication between them.

4.1 Main Segmentation Controls

- VLANs: Virtual LANs divide a physical switching infrastructure into separate Layer 2 broadcast domains. For example, office computers and cameras can be placed in different VLANs.
- Subnets: Each VLAN or security zone is assigned a separate IP subnet. Routers or Layer 3 switches control communication between subnets.
- Internal firewalls: These inspect traffic between internal zones and enforce rules, preventing an infected office endpoint from freely reaching servers or industrial systems.
- Access Control Lists (ACLs): ACLs permit or deny traffic based on source, destination, protocol and port. They provide basic traffic restrictions on routers and switches.
- DMZ: A separate zone hosts systems that must communicate with less-trusted networks, such as external-facing portals, remote-access gateways or vendor access brokers.
- Micro-segmentation: Fine-grained controls restrict communication between individual workloads, servers or devices, even within the same broad zone.

4.2 Proposed Zone-Based Architecture

The network should be divided into at least six zones: office, server, DMZ, guest, camera/IoT and production/OT. A dedicated management zone or jump-host segment should also be used for privileged administration.

Zone	Example assets	Security purpose
Office zone	Employee laptops and desktops	Normal business work; no direct access to production controllers.
Server zone	ERP, file, database and identity servers	Protect business-critical applications and data.
DMZ	Public portal, remote-access gateway, vendor access gateway	Host services that communicate with external or lesstrusted networks.
Guest zone	Visitor and personal devices	Internet-only access; isolated from corporate and operational systems.
Camera / IoT zone	IP cameras, recorders and sensors	Restrict devices to their recorder, management service and required update destinations.
Production / OT zone	PLCs, HMIs, industrial controllers and engineering workstations	Protect availability and safety of production processes.
Management zone	Privileged admin workstation and jump host	Provide controlled administration with MFA and session logging.

4.3 Allowed Traffic Between Zones

Source zone	Destination zone	Allowed traffic	Reason
Office	Server	Approved ERP application ports and required identity/DNS services	Allow employees to use business systems without unrestricted server access.
Office	DMZ	HTTPS to approved company portals	Allow access to published services.
DMZ	Server	Only specific application-to-database or applicationto-service ports	Allow required backend functions; block general DMZ access.
Guest	Internet	DNS and web traffic through filtering	Provide visitor connectivity while isolating company assets.
Guest	Office / Server / Production	Deny all	Prevent untrusted devices from reaching internal systems.
Camera / IoT	Recorder / management server	Only required camera streaming and management ports	Allow monitoring while limiting lateral movement.
Camera / IoT	Office / Server / Production	Deny by default; allow documented exceptions only	Prevent compromised cameras from reaching sensitive systems.
Management zone	Server zone	SSH/RDP or approved management protocols to named hosts	Allow controlled server administration.
Management zone	Production / OT	Approved engineering protocols through jump host, during authorised windows	Permit necessary maintenance with oversight.
Office / DMZ / Guest	Production / OT	Deny all direct access	Stop office malware from reaching industrial controllers.
Production / OT	Server zone	Only required historian, reporting or patchmanagement flows	Support business reporting without opening broad inbound access.
Any zone	Any zone	Deny and log all other traffic	Enforce least privilege and provide visibility.

4.4 Secure Administrative Access to Production

Administrators should not connect directly from ordinary office laptops to production controllers. They should use a hardened privileged workstation and connect to a dedicated jump host in the management zone. The jump host must require MFA, individual accounts and role-based permissions. Administrative sessions should be recorded or logged, access should be time-limited and approved, and file transfers to the OT zone should be scanned and controlled. Emergency access should be documented and reviewed after use.

4.5 Principles of Secure Architecture

- Least privilege: Each user, device and service receives only the minimum network and system permissions required for its task.
- Simplicity: A clear zone model and small, understandable rule set reduce configuration mistakes and make reviews easier.
- Fail-safe defaults: Unmatched traffic is denied. A failure should not automatically open access to critical systems.
- Redundancy: Critical firewalls, switches, power supplies and network paths should have suitable backups to maintain availability.
- Separation of duties: No single person should have unchecked control over every security approval, production change and audit activity.

4.6 Costs and Limitations

Segmentation requires investment in managed switches, firewalls, monitoring, design and staff training. It can increase administration effort and may cause compatibility problems with older industrial equipment or applications that rely on broad network access. Incorrect rules can interrupt production or prevent legitimate services from working. Some legacy devices may not support modern authentication or endpoint agents. The company should therefore inventory assets, map communication flows, test changes in a controlled environment and roll out segmentation in phases with rollback plans. A properly segmented architecture would have limited the ransomware incident to the office zone and prevented direct movement to ERP and production systems, reducing both business impact and recovery time.

QUESTION 5

Zero Trust and Defense-in-Depth for a Financial Services Firm

The breach began with stolen VPN credentials and succeeded because the firm trusted devices and users after they entered the internal network. A traditional perimeter-only model is not sufficient for a cloud-based organisation with many remote employees. Zero Trust should be adopted together with defense in depth so that every access request is verified and multiple independent controls limit the impact of a breach.

5.1 Principles of Zero Trust

- Never trust, always verify: Do not grant access only because a user or device is inside the office network or connected through VPN. Verify identity, device, context and requested resource for every access decision.
- Least privilege: Give users and services only the minimum access required, for the shortest practical period. Use role-based access and just-in-time elevation for administrators.
- Assume breach: Design systems on the assumption that an account, device or network segment may already be compromised. Segment resources, monitor activity and prepare to contain incidents. **5.2 Main Zero Trust Components**

Component	Role in the firm
Identity Provider (IdP)	Centralises user identity, authentication and single sign-on for cloud and internal applications.
Multi-factor authentication (MFA)	Requires an additional factor beyond a password; phishing-resistant MFA should be preferred for staff and administrators.
Device posture checks	Verifies patch level, endpoint protection, disk encryption, device registration and compliance before granting access.
Policy Decision Point (PDP)	Evaluates identity, device health, location, risk, requested resource and business policy to decide whether access is allowed.
Policy Enforcement Point (PEP)	Enforces the PDP decision by allowing, denying or limiting the session at the application, gateway or network boundary.
Micro-segmentation	Separates workloads and sensitive systems so that compromise of one account or server does not provide broad access.
Continuous monitoring	Collects identity, endpoint, application, network and cloud logs; detects unusual behaviour and triggers re-authentication or containment.

5.3 Defense-in-Depth Layers and Controls

Layer	Example control for the financial firm	Purpose
Physical	Badge-controlled data-centre access, visitor logs and CCTV	Prevent unauthorised physical access to servers and network equipment.
Perimeter	Redundant next-generation firewalls, secure gateways and DDoS protection	Filter external traffic and protect public-facing services.
Network	VLANs, micro-segmentation, private cloud networking and restrictive security groups	Limit lateral movement and isolate sensitive workloads.
Host	Endpoint detection and response (EDR), patching, disk encryption and hardening	Detect malware and reduce endpoint compromise.
Application	Secure development, code review, WAF, API authentication and regular testing	Reduce application vulnerabilities and unauthorised API access.
Data	Encryption at rest and in transit, data classification, backups and data-loss prevention	Protect confidentiality, integrity and availability of financial data.
People	Security awareness, phishing simulations and role-based training	Reduce credential theft and social-engineering success.
Policy	Access-control standards, incident-response plans, vendor reviews and periodic audits	Create consistent security responsibilities and measurable compliance.

5.4 Zero Trust Compared with the Traditional Perimeter Model

Aspect	Traditional perimeter model	Zero Trust model
Trust decision	Often trusts users/devices after they enter the internal network or VPN.	Verifies each access request using identity, device, context and resource policy.
Main security boundary	Mainly the office network and perimeter firewall.	Identity, device, application and data boundaries across cloud and on-premises systems.
Lateral movement	May be easier after an attacker enters the network.	Restricted through least privilege and microsegmentation.
Remote and cloud access	Can require traffic to return through a central VPN gateway.	Can provide policy-controlled access close to the application or resource.
Monitoring	Often focuses on the perimeter and network traffic.	Continuously evaluates identity, endpoint, application and network signals.

Zero Trust does not mean removing firewalls or VPNs. Perimeter controls remain useful for blocking unsolicited traffic and protecting public services. Zero Trust adds identity- and context-based checks inside and outside the perimeter. The

two approaches complement each other: perimeter security reduces exposure, while Zero Trust limits what a compromised account or device can access.

5.5 Phased Implementation Roadmap

7. Phase 1 – Discover and prioritise: Inventory users, devices, applications, cloud workloads, data stores and thirdparty connections. Identify critical financial systems and high-risk accounts.
8. Phase 2 – Strengthen identity: Centralise authentication through the IdP, enforce MFA, remove shared accounts, review privileged roles and introduce conditional access.
9. Phase 3 – Improve device trust: Enrol corporate devices, deploy EDR, enforce patching and encryption, and block or restrict non-compliant devices.
10. Phase 4 – Protect applications and data: Place sensitive applications behind policy enforcement points, classify data, encrypt it and apply least-privilege application permissions.
11. Phase 5 – Segment networks and workloads: Separate production, development, administration and sensitive data environments. Introduce micro-segmentation gradually and test application dependencies.
12. Phase 6 – Monitor and improve: Centralise cloud, identity, endpoint and network logs in a SIEM. Create detection rules for impossible travel, unusual downloads, privilege escalation and suspicious session behaviour. Test incident-response procedures.

5.6 Likely Difficulties and Mitigations

- Legacy systems: Older applications may not support modern authentication or agents. Use compensating controls such as secure gateways, network isolation and tightly scoped service accounts while planning upgrades.
- User resistance: Repeated MFA prompts and access restrictions may frustrate staff. Explain the security benefits, provide clear support and use risk-based policies without weakening essential controls.
- Cost and complexity: Identity platforms, endpoint tools, cloud controls and monitoring require budget and skilled staff. Prioritise high-risk applications first and implement in phases.
- Application dependencies: Restrictive policies may break integrations or business workflows. Map dependencies, test in monitor-only mode where available and maintain documented rollback procedures.
- Alert volume and privacy: Continuous monitoring creates large volumes of data and may involve employee information. Define retention, access and privacy rules, and tune detections to meaningful risk.

The firm should not treat VPN authentication as proof that a user is trustworthy. A phased Zero Trust programme, supported by defense-in-depth controls, will make stolen credentials less useful, restrict lateral movement and improve the organisation’s ability to detect and contain future attacks.